

Information Security Overview

The Importance of Information Protection

- Information is an important asset. The more information you have at your command, the better you can adapt to the world around you.
- In business, information is often one of the most important assets a company possesses.
- Information differentiates companies and provides leverage that helps one company become more successful than another
- Information intended for internal use only is usually meant to be seen by employees, contractors, and service providers, but not by the general public.
- Examples include internal memos, correspondence, general e-mail and instant message discussions, company announcements, meeting requests, and general presentation materials.
- This type of information is typically the least restricted—because spending a lot of time and money on protecting it doesn't outweigh the value of the information or the risk of its disclosure.

The Evolution of Information Security

In the early days of networking, individual computers were connected together only in academic and government environments. Thus, at that time, the networking technologies that were developed were specific to academic and government environments. Originally, the academic security model was “wide open” and the government security model was “closed and locked.” There wasn’t much in between. The government was mainly concerned with blocking access to computers, restricting internal access to confidential data, and preventing interception of data (for example, by shielding equipment to prevent electromagnetic radiation from being intercepted). This method of protecting assets provided a hard-to-penetrate perimeter, as depicted in Figure 1-1.

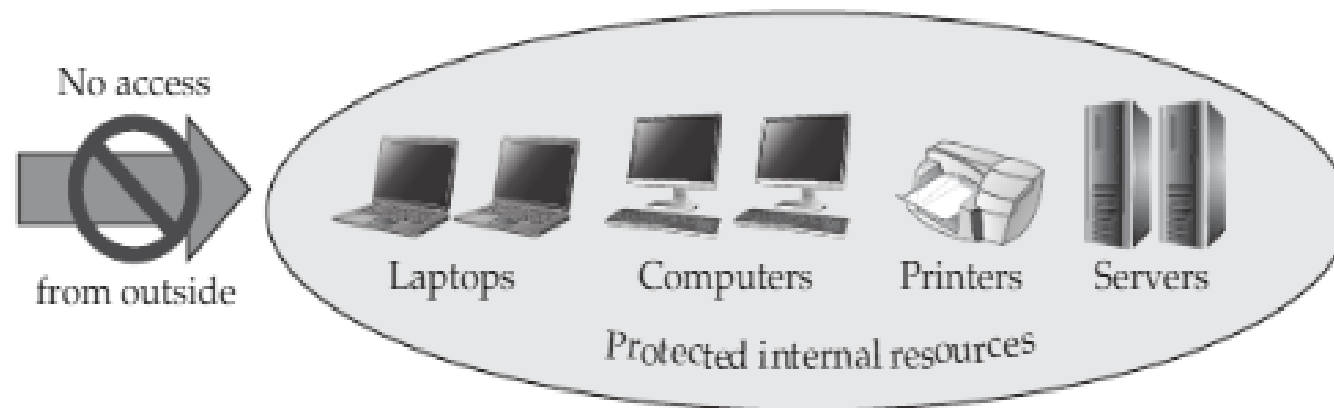


Figure 1-1 Original government perimeter blockade model



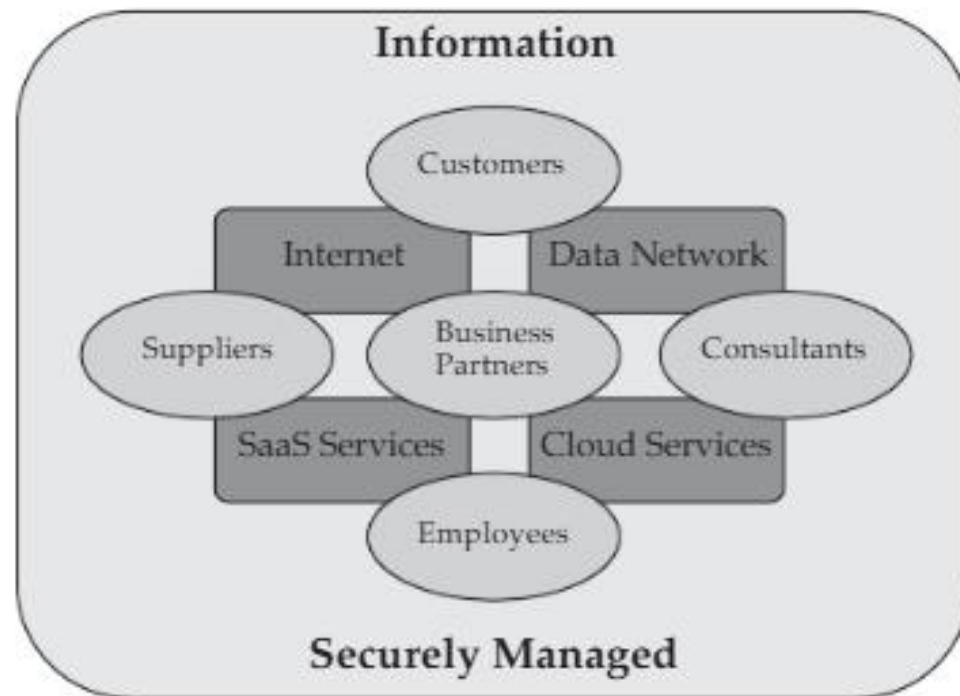


Figure 1-3 Modern information is shared among many consumers, via many channels.

threats to all these information resources have evolved at a rate equal to or greater than the technologies themselves. (Chapter 2 covers modern threats in detail.)

Modern security products are now designed to balance the needs of business on the Internet while protecting against today's sophisticated threats. Modern information security practices have evolved into a blended approach to managing access to information. Technology and information are blended into everyday life, and they can no longer be kept in a locked box or left unprotected.

Justifying Security Investment

- How do you justify spending money on security? That is perhaps the most challenging, and debated, topic in the field of information security. First there was FUD—fear, uncertainty, and doubt.
- Without really measuring anything or delivering specific results, executives were simply frightened into spending money.
- That didn't last long. Soon thereafter, return on investment (ROI) was used as an attempt to market security as an investment that “pays for itself.”
- This was the standard approach to justifying information technology budgets, but it never translated well to security.
- There is really no good way to demonstrate a monetary amount gained by spending money on security.

Business Agility

- Today, every company wants to open up its business operations to its customers, suppliers, and business partners, in order to reach more people and facilitate the expansion of revenue opportunities.
- For example, manufacturers want to reach individual customers and increase sales through e-commerce web sites.
- Web sites require connections to back-end resources like inventory systems, customer databases, and material and resource planning (MRP) applications.
- Extranets need to allow partners and contractors to connect to development systems, source code, and product development resources.
- And SaaS applications deliver business process tools over the Internet to customers.
- Knowledge is power—in business, the more you know, the better you can adapt.

- Strong security provides insight into what is happening on the network and, consequently, in the enterprise.
- Weak security leaves many companies blind to the daily flow of information to and from their infrastructure.
- If a company's competitors have better control of their information, they have an advantage.
- The protection of a company's information facilitates new business opportunities, and business processes require fewer resources when managed efficiently and securely.
- Contemporary security technologies and practices make life easier, not harder.
- Security allows information to be used more effectively in advancing the goals of organization because that organization can safely allow more outside groups of people to utilize the information when it is secure.
- The more access you provide, the more people you can reach—and that means you can do more with less.

Cost Reduction

- Modern security practices do reduce some costs, such as those resulting from loss of data or equipment.
- Data loss due to mishandling, misuse, or mistakes can be expensive.
- A rampant virus outbreak, a web site outage, or a denial of service (DoS) attack can result in service
- outages during which customers cannot make purchases and the company cannot transact
- business. Perhaps even worse, the service outage may attract unwelcome press coverage.
- The consequences of a security compromise can be significant.
- A publicized security incident can severely damage the credibility of a company, and thus its ability to acquire and retain customers.



Portability

THE NEXT LEVEL OF EDUCATION

Portability means that software and data can be used on multiple platforms or can be transferred/transmitted within an organization, to a customer, or to a business partner. The “consumerization” of information has placed demands on companies to be able to provide meaningful and accurate information at a moment’s notice.

- To meet the demands of today's businesses and consumers, architectures and networks need to be designed with security controls baked in as part of the development process.
- Clearly, this level of broad access to information resources requires a well-thought-out and properly deployed security program.
- With sound security built in from the ground up, portability of data as a key benefit can be realized.

Security Methodology

- The field of security is concerned with protecting assets in general. Information security is concerned with protecting information in all its forms, whether written, spoken, electronic, graphical, or using other methods of communication.
- The field of information security evolves constantly, but the foundations of good security practice have not changed throughout history. If you are to succeed in protecting your assets, you should consider the lessons learned from successful security strategies, as well as those learned from poor ones.

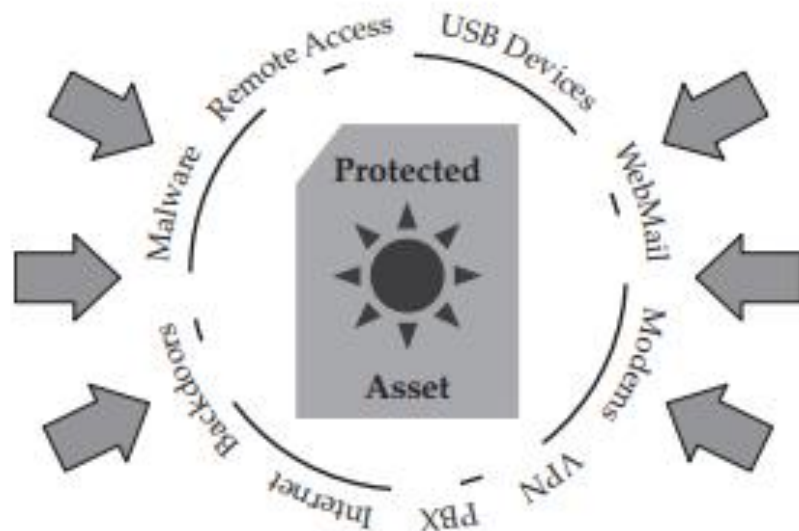
How to Build a Security Program

The overall approach to building a security program, as with any endeavor, should begin with describing what is needed and why, and to proceed to define how it will be implemented, when, and using which particular methods. There are many components that go into the building of a security program:

- **Authority** The security program must include the right level of responsibility and authorization to be effective.
- **Framework** A security framework provides a defensible approach to building the program.
- **Assessment** Assessing what needs to be protected, why, and how leads to a strategy for improving the security posture.
- **Planning** Planning produces priorities and timelines for security initiatives.
- **Action** The actions of the security team produce the desired results based on the plans.
- **Maintenance** The end stage of the parts of the security program that have reached maturity is to maintain them.

The Impossible Job

A universal truth of security, regardless of the application, is that the job of the attacker is always easier than the job of the defender. The attacker needs only to find one weakness, while the defender must try to cover all possible vulnerabilities. Figure 1-6 illustrates this concept. The attacker has no rules—the attacker can follow unusual paths, abuse the trust of the system, or resort to destructive practices. The defender must try to keep their assets intact, minimize damage, and keep costs down. To illustrate this point, let's return to the house analogy. Homeowners who want to protect their property must try to anticipate every attack that is likely to happen, while attackers can simply use, bend, break, or mutilate the house's defenses. In an extreme example, the attacker can cut through the exterior, break the windows, knock down the walls, or set the house on fire. Homeowners have the more difficult job, trying to protect their assets against all types of attack.

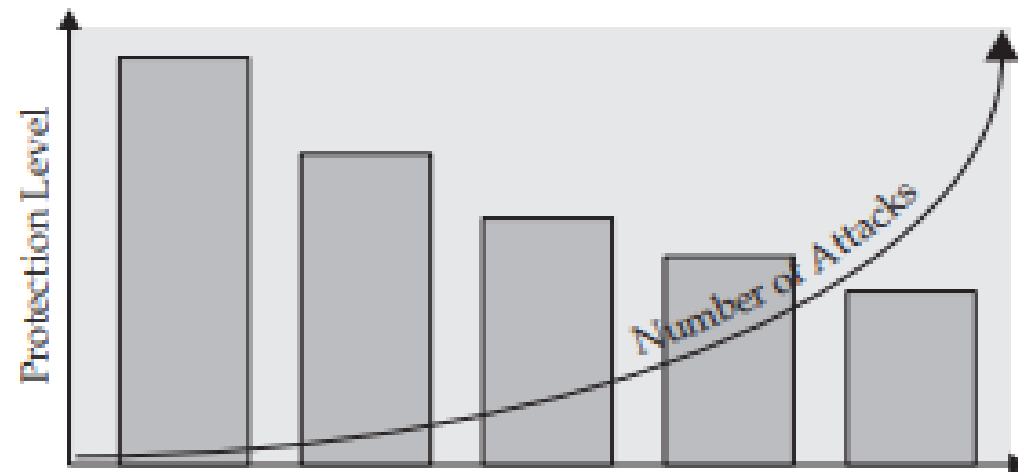


The Weakest Link

THE NEXT LEVEL OF EDUCATION

A security infrastructure will drive an attacker to the weakest link. For example, a potential burglar who is trying to break into a house may start with the front door. If the front door lock is too difficult to pick, the burglar may try side doors, back doors, and other entrances. If the burglar can't get through any of those, he may try to open a window. If they're all locked, he may try to break one. If the windows are unbreakable or barred, he may try to find other weaknesses. If the doors, windows, roof, and basement are all impenetrable, a determined burglar may try to cut a hole in the wall with a chainsaw. In what order will the burglar try these attacks? Usually, from the easiest to the hardest. The weakest link will attract the greatest number of attacks. Figure 1-7 demonstrates this concept.

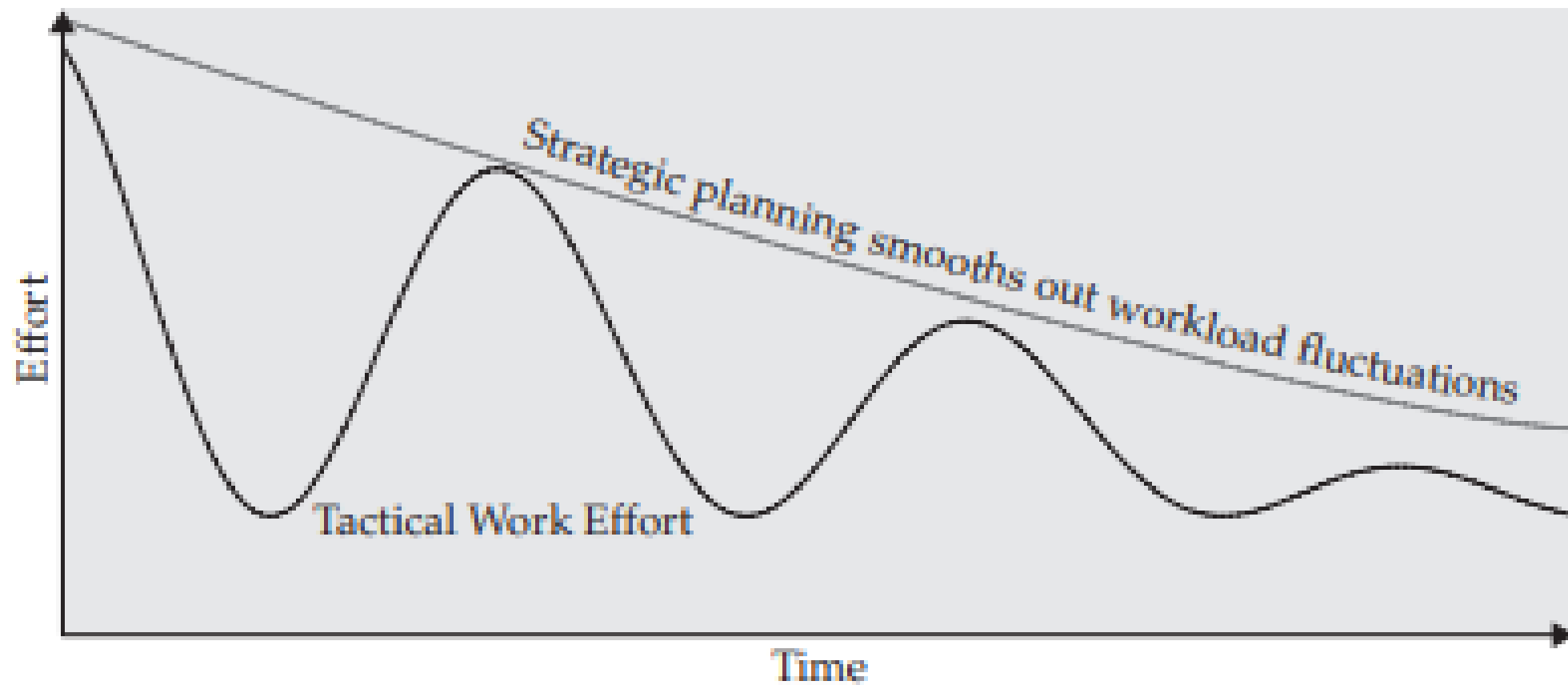
All security controls should complement each other, and each should be equally as strong as the others. This principle is called *equivalent security* or *transitive security*.



For any device that is to be protected, more attacks will occur via less protected paths, and those attacks will typically be more often successful. These attacks may exploit vulnerabilities in Internet-facing systems, compromised internal systems, administrative channels, unsecured paths, or even trusted credentials. The most successful of those attacks will be the ones that take advantage of the weakest security. Spending your limited time and money on improving the security of the firewall, the server, or the database may not be as effective as focusing on greater weaknesses. One objective of an effective security strategy is to force the attacker to spend so much time trying to get past the defenses that he will simply give up and go elsewhere. Other strategies attempt to delay the intruder for a long enough time to take a reactive response, such as summoning authorities. Still others try to lure the attacker into spending too much time on a dead end. In any case, weak points in the security infrastructure should be avoided whenever possible. In situations where weak points are necessary due to business requirements, detective and deterrent security controls should focus on the areas where defensive weak points exist. You can expect these weak points to attract attackers, and you should plan Accordingly

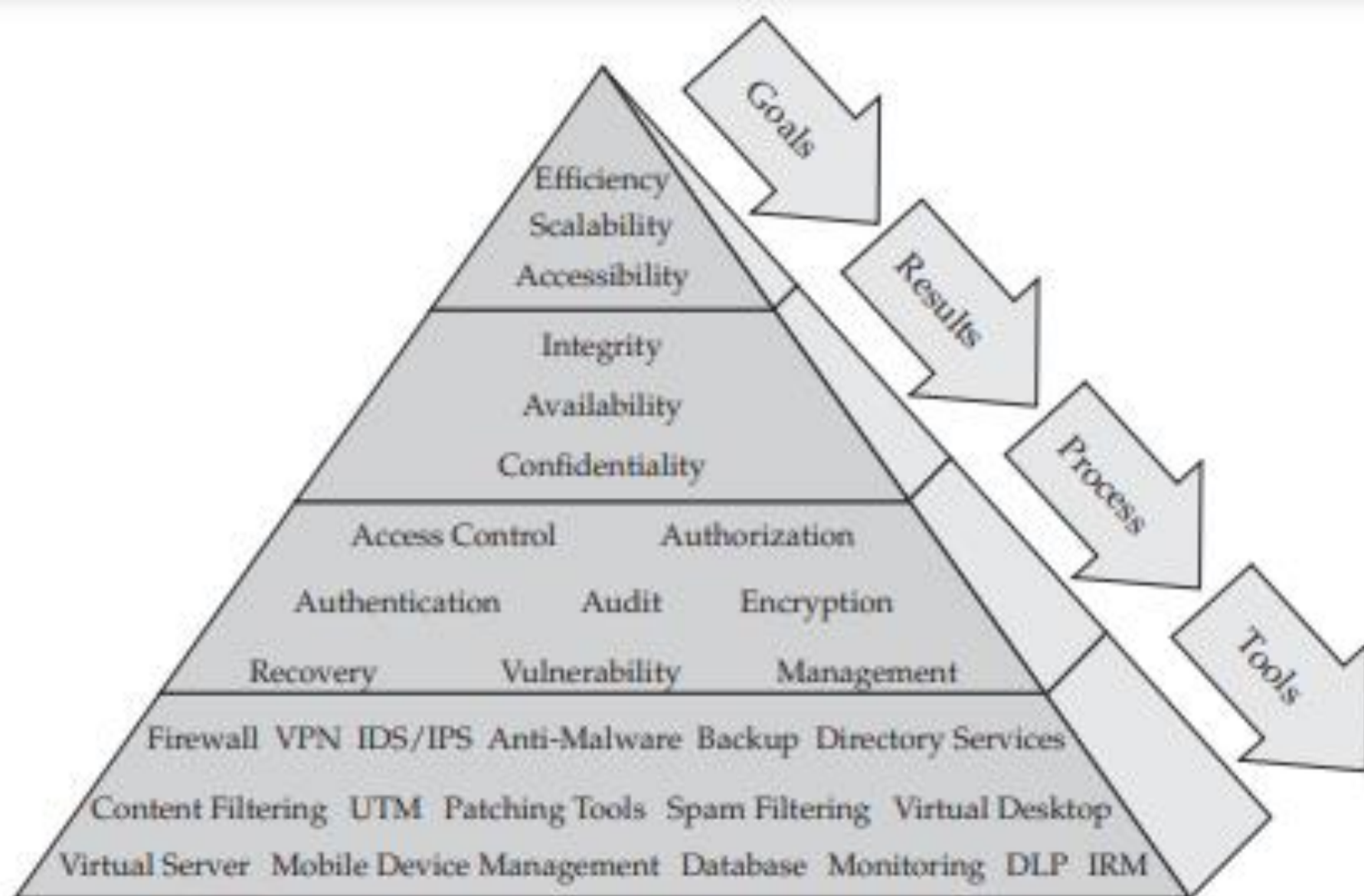
Strategy and Tactics

A security strategy is the definition of all the architecture and policy components that make up a complete plan for defense, detection, and deterrence. Security tactics are the day-to-day practices of the individuals and technologies assigned to the protection of assets. Put another way, strategies are usually proactive and tactics are often reactive. Both are equally important, and a successful security program needs to be both strategic and tactical in nature. With a well-defined strategic plan driving tactical operations, the security effort will have the best chance for success



Business Processes vs. Technical Controls

- Business Processes vs. Technical Controls In security, there is no magic bullet. In this sense, a magic bullet means a single security device, product, or technology that provides complete protection against all threats. Some security products are marketed as “security-in-a-box” solutions that provide all the security a company needs. In reality, security threats and exposures are complex and constantly evolving. Security technologies need to be selected on the basis of business context, so they are targeted toward specifically identified risks with clear objectives. Organizations that place technical controls on their network without accompanying business processes have not recognized that computers are tools for accomplishing specific objectives, and that tools should be considered within a business process in order to be effective. For example, purchasing a database does not solve the problem of how to manage customer data. Customer data management is a business process that can be facilitated by a database. Likewise, buying a firewall doesn’t magically provide security. Furthermore, if technical controls get in the way of the business or slow down workflow, people will find ways to work around them, rendering them ineffective or useless.



- You can never be 100 percent secure.
- You can, however, manage the risk to your assets.
- You have many tools to choose from to manage risk. Used properly, these tools can help you achieve your risk management objectives.

Risk Analysis

- Threat Definition

Evaluating threats is an important part of risk analysis. By identifying threats, you can give your security strategy focus and reduce the chance of overlooking important areas of risk that might otherwise remain unprotected. Threats can take many forms, and in order to be successful, a security strategy must be comprehensive enough to manage the most significant threats.

Types of Attacks

- **Ransomware**
- Hackers take control of a computer and encrypt its files, then demand a ransom to decrypt them.
- **SQL injection**
- Hackers inject malicious code into a website's search box to steal sensitive information.
- **Password attack**
- Hackers try to break into a system or account by compromising user credentials.

- **Spoofing**

- Hackers impersonate people or companies to trick victims into giving up personal information.

- **Phishing**

- Phishing is a type of attack which attempts to steal sensitive information like user login credentials and credit card number. It occurs when an attacker is masquerading as a trustworthy entity in electronic communication.

- **Denial of Service**

- It is an attack which meant to make a server or network resource unavailable to the users. It accomplishes this by flooding the target with traffic or sending it information that triggers a crash. It uses the single system and single internet connection to attack a server.

Risk Analysis

- Risk analysis is the process of identifying, assessing, and prioritizing potential threats to an organization's data and systems. The goal is to understand the likelihood of threats exploiting vulnerabilities and causing damage to the organization's assets.
- **Proactive Defense:** Discovering potential risks by an organization helps in applying preventive measures before incidents strike, reducing successful cyber attacks to a considerable extent.
- **Resource Optimization:** Risks so developed are then priority rated, and, based on a qualitative and quantitative assessment, an organization should be able to allocate its finite resources in a way that portions of areas posing very high risk get reasonable enough attention and funding.

- **Compliance Requirements:** Many industries are controlled by regulatory frameworks that require regular risk assessments. Thorough risk analysis adheres not only to these necessities but also mitigates the risk faced by fines and penalties for non-compliance.
- **Improved Incident Response:** A well-done risk analysis equips an organization with the knowledge of devising and applying robust [incident responses](#) to recover fast in case of a security breach or data leakage.
- **Strengthened Security Culture:** Risk analysis develops the culture of cybersecurity, providing awareness and accountability that employees at whatever level follow best security practices and contribute to the organization's overall security stance.

Secure Design Principles

CIA Triad-

- **Confidentiality, integrity and availability**, also known as the CIA triad, is a model designed to guide policies for information security within an organization.
- The model is also sometimes referred to as the AIC triad (availability, integrity and confidentiality) to avoid confusion with the Central Intelligence Agency.
- The CIA triad is a common, respected model that forms the basis for the development of security systems and policies.
- These are used for the identification of vulnerabilities and methods for addressing problems and creating effective solutions.

Examples of CIA Triad

- The two-factor authentication (debit card with the PIN code) provides confidentiality before authorizing access to sensitive data.
 - The ATM and bank software ensure data integrity by maintaining all transfer and withdrawal records made via the ATM in the user's bank accounting.
-

Examples of CIA Triad

- The two-factor authentication (debit card with the PIN code) provides confidentiality before authorizing access to sensitive data.
- The ATM and bank software ensure data integrity by maintaining all transfer and withdrawal records made via the ATM in the user's bank accounting.



Confidentiality

- Confidentiality involves the efforts of an organization to make sure data is kept secret or private.
- To accomplish this, access to information must be controlled to prevent the unauthorized sharing of data—whether intentional or accidental.
- A key component of maintaining confidentiality is making sure that people without proper authorization are prevented from accessing assets important to your business. Conversely, an effective system also ensures that those who need to have access have the necessary privileges.
- For example, those who work with an organization's finances should be able to access the spreadsheets, bank accounts, and other information related to the flow of money. However, the vast majority of other employees—and perhaps even certain executives—may not be granted access. To ensure these policies are followed, stringent restrictions have to be in place to limit who can see what.

Integrity

- Integrity involves making sure your data is trustworthy and free from tampering. The integrity of your data is maintained only if the data is authentic, accurate, and reliable.
- For example, if your company provides information about senior managers on your website, this information needs to have integrity. If it is inaccurate, those visiting the website for information may feel your organization is not trustworthy. Someone with a vested interest in damaging the reputation of your organization may try to hack your website and alter the descriptions, photographs, or titles of the executives to hurt their reputation or that of the company as a whole.
 - **Availability**
 - Even if data is kept confidential and its integrity maintained, it is often useless unless it is available to those in the organization and the customers they serve.
 - This means that systems, networks, and applications must be functioning as they should and when they should.

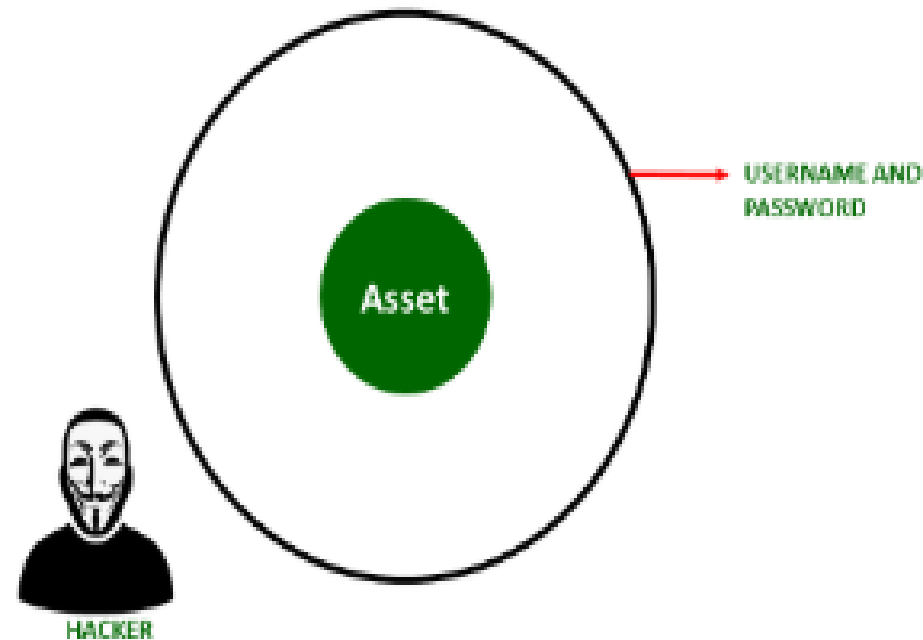
- Also, individuals with access to specific information must be able to consume it when they need to, and getting to the data should not take an inordinate amount of time.
- If, for example, there is a power outage and there is no disaster recovery system in place to help users regain access to critical systems, availability will be compromised. Also, a natural disaster like a flood or even a severe snowstorm may prevent users from getting to the office, which can interrupt the availability of their workstations and other devices that provide business-critical information or applications. Availability can also be compromised through deliberate acts of sabotage, such as the use of denial-of-service (DoS) attacks or ransomware.

Introduction To Security Defense Models

1. Lollipop Model :

Lollipop Model is Defense Model associated with an analogy of a Lollipop. A lollipop is having a chocolate in the middle and around the chocolate, there is a layer of crust, mainly of sugar flavored syrup. A person licks and licks the lollipop and finally, the chocolate in the middle is exposed.

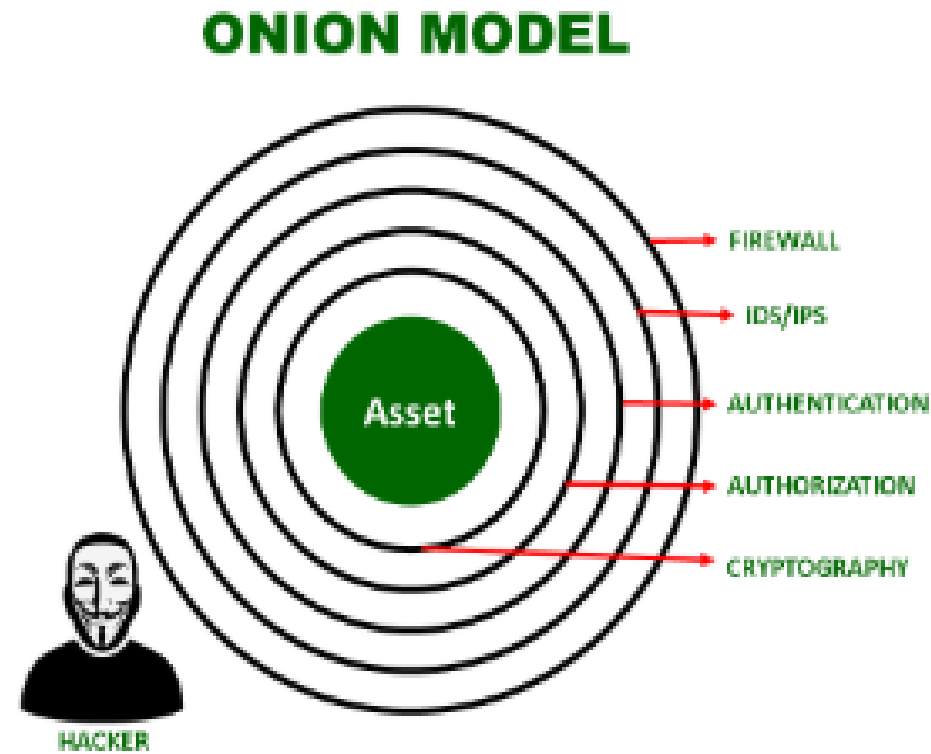
LOLLIPOP MODEL



Mapping this analogy of Lollipop to the Model, as shown in the above diagram, the hacker just needs to break that one layer of security to get hands on the asset, in this case, say it is Username and Password. Once it is done, the hacker can access the asset. So Lollipop Model is not a good model for Network Security.

2. Onion Model :

Onion Model is Defense Model associated with an analogy of an Onion. An Onion is a vegetable which is composed of layers. Only by peeling each layer, we can get to the center of the Onion. Also, while peeling, we get tears in our eyes.



Mapping this analogy of Onion to the Model, as shown in the above diagram, the hacker needs to break all the layers of security to get access to the asset. Breaking each layer i.e., [Firewall](#), IDS/IPS, [Authentication](#), Authorisation, and [Cryptography](#) in this case, should bring tears to his eyes. In simple words, breaking each layer should be complex and extremely challenging for the hacker. So Onion Model is considered as a good model for [Network Security](#).

zones of trust

- zones of trust are sections of a network that are separated based on the level of trust for the data, devices, and applications within them. They are used to improve security by limiting the flow of information between different parts of a network.
- How zones of trust work
- **Identify critical resources**
- Identify which resources are most critical and need the highest level of protection
- **Create zones**
- Separate the network into zones based on the criticality of the resources in each zone
- **Apply security measures**
- Apply different security measures to each zone based on the sensitivity of the information it contains

Network defense best practices include

- **Using strong passwords:** Use a mix of uppercase and lowercase letters, numbers, and symbols. Avoid using dictionary words or keyboard patterns.
- **Updating software:** Keep your operating system and applications up to date.
- **Using multi-factor authentication (MFA):** Require MFA for all accounts.
- **Educating employees:** Teach employees about phishing, strong passwords, and data protection.
- **Backing up data:** Create a strategy for backing up data and ensure that third-party providers are reliable.
- **limiting access:** Limit access to administrator accounts and only grant temporary permissions for privileged tasks.